

Aula 2 (Módulo 03) — ARP e ICMP

1. O problema que o ARP resolve

Na Aula 1, vimos que dentro de uma LAN os dispositivos têm **dois** endereços diferentes: o **MAC** (do hardware) e o **IP** (lógico). Mas quando o seu computador quer enviar dados para `192.168.1.20` (um IP), o hardware de rede (Ethernet) só entende endereço **MAC** — ele não sabe "falar" em IP diretamente. É preciso descobrir: "qual é o endereço MAC da máquina que tem o IP 192.168.1.20?"

2. ARP (Address Resolution Protocol)

ARP é o protocolo que resolve exatamente essa pergunta, dentro de uma LAN:

```
Seu computador: "Quem tem o IP 192.168.1.20? Me diga seu MAC!" (broadcast – pergunta para TODOS na LAN)
Máquina .20:    "Sou eu, meu MAC é AA:BB:CC:DD:EE:FF" (resposta direta, só para quem perguntou)
```

Seu computador guarda essa resposta em uma **tabela ARP** (cache local), para não precisar perguntar de novo toda vez:

```
ip neigh show      # Linux – mostra a tabela ARP atual
arp -a             # Windows – mesmo conceito
```

3. ARP Spoofing — o ataque clássico contra ARP

O protocolo ARP, por design, **não verifica se a resposta é verdadeira** — qualquer máquina na LAN pode responder "sou eu" para um IP que não é dela. **ARP Spoofing** (ou ARP Poisoning) explora exatamente isso: um atacante na mesma rede local envia respostas ARP falsas, dizendo "o IP do roteador é o MEU MAC" — fazendo com que outras máquinas da rede enviem o tráfego delas **para o atacante** em vez de para o roteador de verdade.

```
Normal:    [Vítima] → tráfego → [Roteador real]
Com ARP Spoofing: [Vítima] → tráfego → [Atacante] → (opcionalmente repassa) → [Roteador]
```

Isso é chamado de ataque **"Man-in-the-Middle" (MITM)**: o atacante se posiciona no meio da comunicação, podendo ler (ou até alterar) o tráfego da vítima, sem que ela perceba.

Por que importa para segurança: ARP Spoofing só funciona **dentro da mesma rede local** (é a limitação principal do ataque) — outro motivo pelo qual segmentação de rede (Aula 1) reduz o risco. Detecção tipicamente envolve monitorar a tabela ARP em busca de um mesmo IP "trocando" de MAC repentinamente (isso é um forte indicador — em uma rede saudável, o MAC de um IP normalmente não muda sem motivo). Vamos formalizar essa detecção com ferramentas próprias (como Zeek/Suricata) no Módulo 04.

4. ICMP (Internet Control Message Protocol)

ICMP é o protocolo usado para enviar mensagens de **controle e diagnóstico** de rede — não transporta dados de aplicação (como um e-mail ou uma página web), serve para a própria rede "conversar sobre si mesma": avisar erros, testar conectividade.

O uso mais conhecido do ICMP é o comando `ping` :

```
ping 8.8.8.8
```

O `ping` envia uma mensagem ICMP do tipo **Echo Request** ("você está aí?") e espera uma resposta **Echo Reply** ("sim, estou aqui") — medindo o tempo de ida e volta (latência). Se não houver resposta, pode significar que o host está fora do ar, ou que algum firewall no caminho está **bloqueando ICMP** deliberadamente (muitos administradores bloqueiam ping por padrão, justamente por questões de segurança — ver abaixo).

Outro uso comum: `traceroute` (Linux/macOS) ou `tracert` (Windows), que usa ICMP de um jeito mais elaborado para mostrar **cada salto** (roteador) pelo qual o tráfego passa até chegar ao destino.

```
traceroute 8.8.8.8    # Linux/macOS
tracert 8.8.8.8       # Windows
```

Por que importa para segurança: ICMP também é usado, de forma abusiva, para **reconhecimento de rede** (um atacante faz "ping sweep" — tenta ping em toda uma faixa de IPs para descobrir quais máquinas estão ativas, antes de atacar) e, historicamente, até para **exfiltração de dados** de forma disfarçada (esconder dados dentro de pacotes ICMP, que muitos firewalls inspecionam menos do que tráfego HTTP/HTTPS — técnica chamada de **ICMP tunneling**). Por isso, é comum ambientes corporativos restringirem ICMP na borda da rede, mesmo sabendo que isso dificulta um pouco o diagnóstico legítimo — é uma troca (trade-off) consciente entre usabilidade e segurança.

5. Conectando tudo

```
ARP → resolve IP → MAC, DENTRO da LAN; sem autenticação → alvo de
      ARP Spoofing (MITM)
ICMP → mensagens de controle/diagnóstico (ping, traceroute); também
      abusado para reconhecimento (ping sweep) e, raramente,
      exfiltração (ICMP tunneling)
```

Ambos são protocolos "de apoio" — não carregam o conteúdo real de uma aplicação (isso vem com TCP/UDP, próxima aula), mas são essenciais para a rede funcionar, e por isso mesmo viram alvo/ferramenta de ataque.

6. Exercício prático

```
ip neigh show
ping -c 4 8.8.8.8
tracroute 8.8.8.8 2>/dev/null || tracert 8.8.8.8
```

Observe na tabela ARP (`ip neigh show`) quais IPs e MACs da sua rede local seu computador já conhece. No `ping` , observe o tempo de resposta (latência) de cada pacote. No `tracroute` , observe quantos "saltos" (roteadores) existem entre você e `8.8.8.8` (um dos servidores DNS públicos do Google) — cada linha é um roteador diferente pelo caminho.

7. Recapitulando

- ARP traduz IP → MAC dentro da LAN; não tem autenticação, o que permite ARP Spoofing (ataque MITM).
- ICMP é o protocolo de controle/diagnóstico de rede — base do `ping` e `tracroute` .
- ICMP também é abusado para reconhecimento (ping sweep) e, ocasionalmente, exfiltração disfarçada (ICMP tunneling).
- Ambos operam "por baixo" da camada de aplicação — servem a própria rede, não carregam dados de usuário diretamente.

Próxima aula

TCP e UDP, e o conceito de **porta** — como múltiplos serviços convivem no mesmo IP, e a diferença fundamental entre uma conexão confiável (TCP) e uma comunicação "solta" (UDP).

Fontes recomendadas

- **RFC 826 — "An Ethernet Address Resolution Protocol (ARP)"**: especificação técnica oficial do ARP. <https://www.rfc-editor.org/rfc/rfc826>
- **RFC 792 — "Internet Control Message Protocol"**: especificação técnica oficial do ICMP. <https://www.rfc-editor.org/rfc/rfc792>
- **MITRE ATT&CK — T1557.002 (Adversary-in-the-Middle: ARP Cache Poisoning)**: técnica oficial de ARP Spoofing. <https://attack.mitre.org/techniques/T1557/002/>